TaskFlow Software – API Injection Incident Response Playbook

Playbook ID: IR-PB-003
Incident Type: API Injection Attack
Severity: High (Critical if data compromise is confirmed)
Primary Owner: SOC Analyst
Environment: TaskFlow Software SaaS Beta
Status: Draft – Pending Tabletop Validation

1. Purpose

This playbook defines procedures for detecting, investigating, containing, and recovering from injection attacks targeting TaskFlow's REST API.

The objective is to prevent unauthorized database access, protect customer information, and maintain the integrity and availability of SaaS services.

2. Affected Assets

Asset ID	Asset Name	Risk Level
TF-002	REST API	Critical
TF-003	Customer Database	Critical
TF-001	Web Application	Critical
TF-004	Authentication Service	Critical
TF-007	Logging and Monitoring System	High

Primary risk: Attackers may exploit insecure API input handling to access, modify, or delete sensitive information.

3. Detection and Identification

Responsible: SOC Analyst

1. Review web injection detection alerts in Elastic Security/Kibana.
2. Identify suspicious API requests, unusual parameters, and repeated request failures.
3. Examine HTTP methods, response codes, timestamps, and source IP addresses.
4. Correlate API activity with authentication and database logs where available.
5. Determine whether the activity represents an attempted or successful injection.
6. Preserve relevant alert IDs, request logs, and supporting evidence.

Detection source: Web injection detection rule and Elastic Security monitoring.

4. Incident Response Procedures

Phase 1 – Preparation

Responsible: SOC Analyst / Application Owner

- Review critical assets and risk scores in `assets.json`.
- Confirm access to API logs and Elastic Security.
- Identify available API protection and rate-limiting controls.
- Confirm escalation contacts and authorization procedures.

Phase 2 – Analysis and Classification

Responsible: SOC Analyst

- Review suspicious requests and associated source IP addresses.
- Identify affected API endpoints and potentially exposed data.
- Determine whether the attack caused unauthorized access or data modification.
- Correlate findings with database and authentication activity.
- Escalate confirmed customer data compromise as a critical incident.

Phase 3 – Containment

Responsible: System Administrator / Application Owner

- Apply approved WAF or API gateway restrictions to verified malicious traffic.
- Temporarily restrict vulnerable endpoints when necessary and authorized.
- Revoke compromised credentials or API tokens.
- Preserve relevant logs before making disruptive changes where feasible.
- Monitor for continued attacks from other sources.

Phase 4 – Eradication

Responsible: Application Developer / System Administrator

- Identify and fix vulnerable input-handling logic.
- Use parameterized database queries where applicable.
- Enforce server-side input validation and authorization checks.
- Review API permissions and restrict unnecessary database privileges.
- Deploy tested security fixes through approved change procedures.

Phase 5 – Recovery

Responsible: Application Owner / SOC Analyst

- Test affected API endpoints after remediation.
- Verify authentication, authorization, and database integrity.
- Restore normal endpoint access after approval.
- Monitor Elastic Security for repeated injection attempts.
- Confirm that legitimate API requests function correctly.

Phase 6 – Lessons Learned

Responsible: SOC Analyst / Application Owner

- Document the attack timeline, affected assets, and response decisions.
- Identify weaknesses in API security and monitoring.
- Improve injection detection rules and alert correlation.
- Recommend secure coding reviews and regular API security testing.
- Update the playbook based on tabletop findings.

5. Escalation and Responsibilities

Role	Responsibility
SOC Analyst	Investigate alerts, preserve evidence, coordinate response
System Administrator	Apply approved network and access restrictions
Application Developer	Fix vulnerable code and test security changes
Application Owner / Management	Approve disruptive changes and incident closure

In TaskFlow's single-analyst environment, the SOC Analyst coordinates escalation to the relevant technical owners.

6. Closure Criteria

The incident may be closed when:

- The affected API endpoints have been investigated and secured.
- Confirmed vulnerabilities have been remediated.
- Unauthorized access or data modification has been assessed.
- Legitimate application functionality has been verified.
- Monitoring shows no continuing related malicious activity.
- Evidence and improvement recommendations are documented.
- The incident owner approves closure.

References: `assets.json`, web injection detection rule, Elastic Security dashboard.

Note: This playbook describes proposed response actions. Effectiveness will be assessed through the tabletop exercise; the procedures have not yet been validated in a live incident.